WiFiSecLab 研究计划

面向 IEEE 802.11 接入点的上下文感知状态安全测试

陈家森 江天豪 王梓权 王奥鑫

2026 年 10 月 10 日修订稿

摘要

本研究拟构建 WiFiSecLab 测试平台，依据 IEEE 802.11 的协议规则自主构造测试报文，与受控目标接入点交互，接收并关联目标响应，检验其在给定上下文中是否完成预期状态转换。研究以 IEEE Std 802.11-2024 为主要规范依据，结合近三十年无线协议漏洞文献，提取造成状态处理错误的机制，并将其转化为可追溯的测试条件与判定规则。

首阶段聚焦基础设施网络中的 WPA2-Personal，覆盖认证与关联、四次握手、密钥配置、受控端口授权、受保护数据处理及断开清理。平台将报文观察与目标内部接受证据分开，将无法确认的结果明确记为证据不足。研究重点是如何构造具备正确前置上下文的输入，以及如何在重传、延迟、会话更替和失败恢复等边界下判定 AP 行为。完整通用客户端实现和所有 802.11 模式的覆盖不作为首阶段目标。

预期形成标准条款与漏洞成因知识库、状态约束和证据模型、分阶段测试执行框架以及可复核的跨实现评价材料。能否发现新漏洞是研究结果之一，不预设为项目成立的条件。

1 研究背景与问题定义

IEEE 802.11 的安全连接由多个机制共同完成。认证成功、关联成功、握手消息校验、密钥安装和数据端口放行分别具有不同的前置条件。单独检查一个报文字段或只观察连接是否成功，难以确定实现在哪一步偏离了要求。某些输入在新的会话中属于正常消息，在旧会话中却应忽略；同一重传在空中可能出现多次，实际密钥安装却不能因此重复产生计数器重置等副作用。

历史研究已展示模型驱动测试、密钥重安装分析和跨机制组合分析的价值[2–4]。近年的状态感知 SAE 测试、身份绑定研究及 Wi-Fi 连接协议分析进一步提示，安全结论依赖具体上下文、协议角色和

可获得的证据[5–8]。这些工作为本项目提供成因和方法线索，但其模型与实验条件不能直接替代当前标准或目标 AP 的实际状态。

本研究将核心问题界定为：对于处于特定安全上下文的 AP，测试平台能否产生有明确语义的输入，并利用目标输出及独立证据，判断其是否满足相应状态转换和安全不变量？研究对象是 AP 的协议行为及状态边界。报文解析、网卡控制和抓包是支撑这一目标的基础能力。

2 研究目标与研究问题

项目拟建立一条可追溯的研究流程。首先读标准，明确规则的角色、适用条件和规范强度；随后读相关漏洞论文，提取错误产生的原因；最后修改平台，使报文生成、上下文管理和结果判定覆盖这些原因可能影响的路径。

RQ1 上下文建模。如何用有限的状态变量表达 AP 的阶段、对端身份、安全配置、会话和密钥生命周期，使平台既能区分重要边界，又能控制模型规模？

RQ2 测试生成。与在缺少阶段约束时修改报文相比，依据前置状态和漏洞成因构造输入，能否更有效地到达目标阶段并触发需要复查的行为？

RQ3 状态判定。面对无线丢包、重复采集和内部状态不可见等限制，哪些证据足以支持“符合预期”“候选违例”或“证据不足”，怎样减少误判？

RQ4 泛化与复现。由某一条款或漏洞提取的约束，能否迁移到具有相同成因的其他阶段或机制，并在不同 AP 实现上形成稳定、可解释的结果？

本项目将上下文与证据约束的组合视为待验证的方法贡献，不将“首次实现”或“全面覆盖现代 Wi-Fi”作为未经文献比较即可成立的结论。

3 研究范围与阶段安排

首阶段选择 WPA2-Personal 的 PSK 与 CCMP 基线配置。它具有明确的握手与数据保护路径，便于先建立可审查的前置条件、响应关联和状态判定方法。目标范围包含认证与关联边界、初始四次握手、PTK 更新、密钥及端口生命周期，并逐步扩展至组密钥更新与失败恢复。

对于正常路径，平台需要能够组织报文序列、按接收事件构造必要响应并追踪目标状态。对于异常路径，平台需要明确输入违反的是哪一条约束，以及目标应忽略、拒绝、终止还是执行恢复。测试组件只实现完成这些交互所需的协议能力。标准客户端可用于环境基线和健康检查，平台仍保留自主构造测试报文的能力。

WPA3 SAE、过渡模式、PMF、FT、FILS、WNM sleep、分片与聚合以及多链路等列为后续范围。其扩展顺序由首阶段发现的共性成因和证据需求决定。不同角色、AKM 或模式必须具有独立的适用性描述，不能把一个基线配置下的结论推广到全部 802.11 实现。

当前阶段以规范阅读和平台开发为主，暂不开展新的主动无线测试。后续评价在规则、用例及恢复流程完成审查后实施。所有实体实验限于团队拥有或获明确授权的 AP、终端和隔离测试网络。

4 标准与漏洞文献研究方法

标准阅读以 IEEE Std 802.11-2024 为主线[1]，优先阅读与首阶段有关的认证、关联、RSNA 密钥管理、EAPOL-Key、密钥配置服务和数据保护章节。遇到规范性引用时回查所引用标准。记录 shall、should、may 的区别，以及例外、条件和实现建议。文字精读与状态图、字段图的视觉核验分别登记，尚未核验的内容保留为待办。

每个条款记录版本、章节、协议角色、触发输入、前置状态、允许行为、禁止副作用及所需证据。对描述不一致或含义尚不明确的内容，先记录解释分歧和交叉引用，再决定是否形成强制判据。例如状态摘要不能替代详细处理过程，样例序列也不能独立支持普遍的状态转换要求。

文献调查覆盖约 1997 至 2026 年，检索时从最新成果开始，再沿引文回溯相关历史。检索来源优先采用 IEEE、ACM、USENIX、NDSS、作者论文页及公开研究材料。范围包括状态机逻辑、消息与会话绑定、密钥及计数器生命周期、身份和安全配置协商、分片聚合、失败恢复与补丁回归。调研范围是一项研究计划，不代表目前已完成全部年代的精读。

每篇精读论文记录适用版本、攻击或错误的必要条件、根因、受影响状态、现有防护、评价证据及局限。论文中针对旧版本的漏洞需要与当前标准重新核对，不能依据历史描述直接认定现代设备存在相同问题。论文代码和形式化模型作为补充证据，未运行的证明或实验不登记为已验证。

标准和文献通过统一的规则记录关联到平台模块。若根因是“将重复消息误作首次安装”，则同时检查四次握手、组密钥更新及其他安装入口；若根因是“旧会话事件推进新会话”，则同时审查认证、握手、授权和清理路径。每轮阅读和修改更新 reading-log.md，记录已读范围、代码变更与未解决问题。

5 相关工作与研究定位

模型驱动 Wi-Fi 握手测试表明，按协议阶段组织输入能够发现逻辑行为偏差[2]。本项目继承代表性边界输入和预期结果相结合的方法，进一步研究规则适用条件、会话上下文和证据不足的表达。跨实现差异用于筛选需要复查的情况，不能单独证明安全问题。

KRACK 后续研究以及 WPA2 形式化分析强调，密钥安装的副作用需要跨握手和其他机制分析[3–4]。这促使平台区分握手计数器、数据包号和接收重放状态，并保留对同一密钥材料的生命周期证据。形式化模型的安全结论依赖其假设，本项目不把抽象模型的性质等同于实体 AP 的证明。

SSID Confusion 关注网络身份与认证上下文的关系[5]，SAECRED 研究 SAE 的状态感知报文测试[6]。二者作为身份绑定和状态前置条件的参考。首阶段仍以 WPA2 AP 为中心，后续扩展时再引入各自适用的判据，避免把客户端问题或 SAE 特定规则直接套用于 AP 四次握手。

WCDCAnalyzer 的分解方法为控制复杂协议模型的规模提供参考[7]，AirSnitch 提醒我们关注链路密钥与更高层身份及转发之间的关系[8]。本项目将分阶段组织测试，但保留跨阶段共享的身份、会话、密钥和数据路径约束。无线注入正确性研究则要求平台核查实际空中报文，不能只依赖发送 API 返回值[9]。

相较原方案按 SSID、SAE 和补丁回归划分独立测试，本方案采用统一的 AP 状态测试方法。上述主题按协议阶段及共性根因进入同一规则体系。研究贡献是否成立，将通过与已有方法的具体比较和评价结果判断。

6 平台架构与执行流程

平台由规范与规则库、上下文模型、报文构造、交互执行、观测关联及判定报告组成。规则库决定何种输入适用于当前上下文；构造层生成报文并保留版本和字节摘要；执行层管理等待条件、超时和预算；观测层将接收帧与目标及本轮交互关联；判定层输出结果及证据边界。

上下文至少包括目标 BSSID、测试对端地址、安全配置、关联会话、握手轮次、请求与响应关系、已验证计数器边界、密钥材料标识、授权状态及清理状态。会话标识与握手轮次分开，密钥标识与安装槽位分开。关联更替、重协商及进程重启分别定义失效条件，旧事件不得继续推进新的上下文。

一次用例从可确认的基线开始。平台检查配置和目标身份，执行必要前置交互，到达有证据支持的目标阶段，再构造测试输入并进行有界观察。随后收集日志或控制快照，检查关键状态与恢复情况，输出完整记录。每一步同时定义成功条件、退出条件和证据不足时的处理，避免因本地超时而直接认定 AP 错误。

Linux 控制主机负责调度，主动交互网卡负责测试发送，独立监听网卡负责采集。网卡角色和能力通过实际发现及后续验证确定。独立抓包可核查发送字节和接收响应，却不能证明目标已收到或已接受报文。实体硬件结果与 mac80211_hwsim 的隔离实验结果分别报告。

实现采用功能分层：core 管理模型、计划与阶段证据，protocol 管理认证、关联及 EAPOL/WPA2 语义，network 管理抓包、网卡和传输环境，lifecycle 管理密钥、端口及数据证据。模块接口保留原始证据标识，避免在层间转换时丢失上下文。

7 WPA2 首阶段状态与边界

认证与关联阶段检查目标、对端和安全配置的绑定。认证响应、关联响应及其状态码用于记录空中行为，AP 内部接受仍需适当证据。关联请求中的 RSNE/RSNXE 与后续握手内容分别比较，广告能力、终端请求和实际协商结果不得混为一个配置。

四次握手检查消息方向、Ack/Request、计数器关联、ANonce/SNonce、完整性以及密钥数据上下文。M1 不带可验证 MIC，其内容不能据此改变已在使用的密钥。M2 应对应尚待响应的 M1。M4 的关联还需要本轮发送历史及已接受响应边界。重传与重复抓包分别处理，不能简单规定每一阶段只能出现一次消息。

密钥和授权阶段分别记录配置请求、配置结果、端口状态和受保护数据行为。观察到 M4 或计算出正确 MIC，不足以确认 AP 成功安装密钥。按稳定材料标识检查安装副作用，按相应保护域检查计数器变化。保留槽位变更、删除及再次安装前后的证据，避免只比较当前槽位而漏掉旧材料重用。

断开和恢复阶段检查端口撤销、密钥删除、待处理工作与定时器清理。收到断开帧只能确认观察到该帧，不能代替清理成功的证据。重连后既要检查新会话是否可正常工作，也要检查旧会话事件是否仍能影响它。重协商允许保留旧上下文的具体情况，需按相应条款单独建模。

组密钥更新逐步引入每 STA 响应与 AP 全局切换的区别。WNM sleep、更新失败和正在四次握手的终端具有特殊条件，不能要求所有关联终端都出现同一种响应才能认定更新合法。其他扩展遵循相同原则，先明确角色与条件，再增加判据。

8 测试用例与判定方法

用例定义包含依据条款、相关论文及根因、目标配置、前置证据、输入序列、预期行为集合、禁止副作用、观察窗口、发送预算、恢复步骤和结果证据。正常控制用例与边界用例配对，先确认测试环境能够完成基本路径，再解释特定输入的结果。

输入维度包括消息重复与重传、阶段顺序和延迟、身份及会话冲突、计数器和 nonce 边界、协商配置不一致、密钥材料及槽位关系、失败后的重试与恢复。平台以保持前置条件为基础，优先改变与当前根因直接相关的维度，再研究具有共享状态的组合。输入的结构合法性、密码学校验和协议阶段适用性分别记录。

判定采用四类结果。符合预期表示规则要求和对应证据均已满足。候选违例表示在有效前置条件下，已有证据与规定冲突，仍需复现与根因分析。证据不足表示丢包、不可见状态或缺失前置条件阻止结论。不适用表示目标配置或组件支持范围不满足规则条件。这四类不能用简单的连接成功或失败替代。

黑盒目标主要提供抓包、正常连接及有限健康检查结果。可插桩目标可增加内部接受、驱动配置结果和端口状态。报告明确每条判据的可见性要求。只有空中证据时，不输出内部状态已确认的结论；内部日志也需与会话和时间关联，避免把其他连接的事件归到当前测试。

9 评价设计与有效性控制

评价对象首先采用可插桩的 hostapd/Linux 与隔离 hwsim 环境，再迁移到可控 OpenWrt AP，最后选择条件允许的商用 AP。具体设备数在确认可用硬件、固件和恢复手段后固定，不在本 proposal 中预先声称已有代表性样本。

实验单位定义为设备或实现、固件版本、安全配置、用例版本与独立运行的组合。评价前固定测试输入和预算、种子、观察窗口以及结果分类。对于方法对照，使用相同构造能力和判定规则，仅改变是否依据阶段与上下文选择输入，减少将更强密码学能力或额外证据误算为状态感知效果的风险。

主要指标包括目标阶段可达率、具备证据的状态约束覆盖、候选违例独立复现比例、证据不足比例以及运行和恢复成本。事件种类覆盖与内部状态覆盖分别报告。在可插桩目标上，用内部记录复核空中判定的误报与漏报；黑盒目标无法取得完整真值时报告适用子集，不给出未经验证的总体准确率。

对重要候选结果，在设备重置后独立复跑，保留所有成功、失败和中止记录。重复次数及稳定性阈值在正式评价前登记，并报告比例及不确定性。恢复时间可报告中位数与四分位距。去重依据违反的约束、状态上下文和根因，不能仅凭报文或日志字节不同计算新发现。

厂商之间的行为差异只作为分析入口。补丁效果比较要求同硬件和可比配置下有可核实的新旧固件。若不满足条件，则仅报告版本或实现间差异。丢包、驱动改写、后台扫描、自动重连及信道变化均作为干扰因素记录并控制。

10 前期基础与当前不足

项目已有离线状态模型、分阶段计划与证据摘要，具备基线 WPA2 的认证和关联构造、EAPOL M1–M4 观察及已知 PMK 下的部分完整性校验能力。代码包含 M2/M4 构造、有界握手交互组件、网卡分工、抓包质量及密钥和数据生命周期证据模块。已有历史 hwsim 与生命周期实验记录，可用于后续整理和复核。

上述模块的存在不等于通用实体 AP 测试链路已经完成。当前构造路径限于较窄的 PSK/CCMP 配置，完整组更新协调、多在途请求、Request 独立计数域、更多 AKM 和完整恢复策略仍需完善。状态模型是研究抽象，抓包观察不会自动推进 AP 内部接受状态。

近期修改依据 2024 标准补充了握手重试和 M4 历史关联、EAPOL PDU 与 MSDU 尾部边界、GTK KDE 版本含义等处理。按照当前开发安排，这些修改只完成静态检查，尚未执行新增测试或实体无线实验。历史正常路径不能证明这些新修改正确，也不能证明全部异常路径已覆盖。

后续工作的首要条件是持续补齐规范依据和规则接口，形成能审查的用例及判定链路，再进行离线验证、隔离实验和实体迁移。阅读日志、代码版本、规则版本与后续实验记录共同构成研究可追溯材料。

11 实施计划与预期成果

实施按阶段验收，时间随标准阅读和证据接口的复杂度调整。第一阶段形成 WPA2 条款索引、文献成因分类和模型适用范围，验收条件是关键规则具有来源、角色、前置条件及证据要求。第二阶段完善构造与执行接口，验收条件是正常路径与代表性边界用例具有明确的观察、退出和恢复定义。

第三阶段在可插桩隔离环境中验证规则与执行器，检查判定误报、上下文失效和恢复行为。第四阶段迁移实体 AP 并开展方法对照及跨实现评价。第五阶段对稳定候选结果进行根因分析，整理复现材料和研究报告。当前仍处于前两阶段，主动实验安排需待相应验收完成。

预期交付包括可版本化的条款和漏洞成因知识库、上下文及证据模型、可扩展的报文构造与交互执行框架、WPA2 正常及边界用例集，以及带适用范围的评价报告。交付要求规则能够追溯、结果能够复核、失败能够解释，并明确尚未证明的性质。

主要风险是标准规模和模式组合过大、商用设备内部状态不可见、无线执行不稳定以及可比固件难以获得。项目通过首阶段配置收敛、按证据强度分类、使用可插桩参考目标及独立监听来降低影响。无法满足证据条件时保留证据不足结果，避免为了完成数量指标而扩大结论。

预期学术贡献是：提出适用于 AP 安全状态测试的上下文与证据约束方法，建立规范及漏洞成因到用例的可追溯映射，并评价该方法对阶段可达性、异常复现和判定可靠性的影响。最终结论以完成的评价为依据。敏感实验材料遵循授权范围，若确认新的安全问题，再按负责任披露流程处理。

参考文献

[1] IEEE. IEEE Std 802.11-2024. IEEE Standard for Information Technology—Telecommunications and Information Exchange between Systems—Local and Metropolitan Area Networks—Specific Requirements—Part 11: Wireless LAN Medium Access Control (MAC) and Physical Layer (PHY) Specifications. 2025. 主要依据第 12 章及相关服务原语。

[2] M. Vanhoef, D. Schepers, F. Piessens. Discovering Logical Vulnerabilities in the Wi-Fi Handshake Using Model-Based Testing. ASIA CCS, 2017. https://papers.mathyvanhoef.com/asiaccs2017.pdf

[3] M. Vanhoef, F. Piessens. Release the Kraken: New KRACKs in the 802.11 Standard. CCS, 2018. https://papers.mathyvanhoef.com/ccs2018.pdf

[4] C. Cremers, B. Kiesl, N. Medinger. A Formal Analysis of IEEE 802.11’ s WPA2: Countering the Kracks Caused by Cracking the Counters. USENIX Security, 2020. https://www.usenix.org/system/files/sec20-cremers.pdf

[5] H. Gollier, M. Vanhoef. SSID Confusion: Making Wi-Fi Clients Connect to the Wrong Network. WiSec, 2024. https://papers.mathyvanhoef.com/wisec2024.pdf

[6] M. D. Dar et al. SAECRED: A State-Aware, Over-the-Air Protocol Testing Approach for Discovering Parsing Bugs in SAE Handshake Implementations of COTS Wi-Fi Access Points. IEEE S&P, 2025. 作者论文索引 https://www.mathyvanhoef.com/p/publications.html

[7] Z. Shen, I. Karim, E. Bertino. WCDCAnalyzer: Scalable Security Analysis of Wi-Fi Certified Device Connectivity Protocols. NDSS, 2026. https://www.ndss-symposium.org/wp-content/uploads/2026-s1049-paper.pdf

[8] X. Zhou et al. AirSnitch: Demystifying and Breaking Client Isolation in Wi-Fi Networks. NDSS, 2026. https://www.ndss-symposium.org/wp-content/uploads/2026-f1282-paper.pdf

[9] M. Vanhoef, X. Jiao, W. Liu, I. Moerman. Testing and Improving the Correctness of Wi-Fi Frame Injection. WiSec, 2023. 作者论文索引 https://www.mathyvanhoef.com/p/publications.html